

VirtuEx 시스템 감사 보고서 (3차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 3차 감사 작성일: 2026-03-02 작성: 시스템 감사팀

1. 개요

3차 감사는 2차 감사에서 발견된 50건의 이슈 수정 결과를 검증하고, 수정 과정에서 발생할 수 있는 회귀(regression) 여부를 점검합니다. 백엔드 8개 서비스, 프론트엔드, 인프라 전체를 대상으로 수행되었습니다.

1.1 감사 목적

구분	내용
1차 목표	2차 감사 수정 45건 적용 검증
2차 목표	스킵 4건 + 인지 1건 사유 타당성 재검토
3차 목표	수정 과정 회귀 이슈 확인

1.2 감사 범위

영역	점검 항목 수	발견 이슈
2차 수정 검증	50건	0건 (전부 정상)
회귀 테스트	8개 서비스 + 프론트엔드	0건
신규 발견	코드 전반	0건
합계		0건

2. 2차 감사 수정 검증

2.1 보안 (#1~#7)

#	항목	2차 상태	3차 검증
1	Docker Compose DB 비밀번호 하드코딩	✅ 수정 완료	✅ 검증 완료 — \${POSTGRES_USER:-postgres} / \${POSTGRES_PASSWORD:-postgres} 환경변수 패턴 적용 확인
2	WebSocket CORS 검증 미적용	✅ 수정 완료	✅ 검증 완료 — price.gateway.ts, chat.gateway.ts에 CORS_ORIGIN.split(',') 적용 확인
3	내부 서비스 Rate Limiting 부재	🚧 스킵	✅ 사유 타당 — InternalAuthGuard로 외부 접근 차단, 내부 서비스 간 과도한 제한은 부작용 유발
4	이메일 민감 데이터 로그 노출	✅ 수정 완료	✅ 검증 완료 — 수신자 이메일 마스킹 (u***@domain.com) 적용 확인

5	채팅 참여자 권한 검증 부족	✅ 수정 완료	✅ 검증 완료 — kickUser에 방 생성자 검증 + ForbiddenException 추가 확인
6	Next.js 보안 헤더 미적용	✅ 수정 완료	✅ 검증 완료 — X-Frame-Options, X-Content-Type-Options, Referrer-Policy, X-DNS-Prefetch-Control 헤더 확인
7	Docker 이미지 버전 미고정	✅ 수정 완료	✅ 검증 완료 — kafka-ui:v0.7.2, pgadmin4:8.14, redis-commander:0.8.1, prometheus:v2.54.0, grafana:11.4.0, jaeger:1.62 고정 확인

2.2 에러 핸들링 (#8~#11)

#	항목	2차 상태	3차 검증
8	가격 알림 에러 무시	✅ 수정 완료	✅ 검증 완료 — .catch(() => {}) → logger.warn 전환 확인
9	주문 프록시 알림 실패 무시	✅ 수정 완료	✅ 검증 완료 — Logger import 추가 + logger.warn 적용 확인
10	로그인 로그 생성 실패 무시	✅ 수정 완료	✅ 검증 완료 — logger.warn 적용 확인
11	시세 데이터 발행 실패 무시	✅ 수정 완료	✅ 검증 완료 — logger.warn 적용 확인

2.3 데이터 무결성 (#12~#22)

#	항목	2차 상태	3차 검증
12	Balance 서비스 any 타입	✅ 수정 완료	✅ 검증 완료 — string 타입 적용 (3개소)
13	프론트엔드 any 타입 다수	✅ 수정 완료	✅ 검증 완료 — LoginSmsModal 타입 정의, useOrders Record<string, unknown>[] 적용
14	i18n 키 강제 타입 캐스팅	✅ 수정 완료	✅ 검증 완료 — orders.side, orders.executedAt 키 추가, as any 제거
15	Portfolio 쿼리 파라미터 미검증	✅ 수정 완료	✅ 검증 완료 — Math.min(100, Math.max(1, ...)) bounds check 적용
16	내부 API symbol 미검증	✅ 수정 완료	✅ 검증 완료 — /^[A-Z]{2,10}(-USD)?\$/ 정규식 검증 적용
17	채팅 헤더 디코딩 미검증	✅ 수정 완료	✅ 검증 완료 — try-catch + .slice(0, 100) 적용
18	가격 알림 트리거 경쟁 조건	✅ 수정 완료	✅ 검증 완료 — DB 실패 시 캐시 복원 로직 확인

19	뉴스 스크래핑 동시 실행 방지	✅ 수정 완료	✅ 검증 완료 — isScraping 플래그 + try/finally 패턴 확인
20	Order Engine @updatedAt 누락	✅ 수정 완료	✅ 검증 완료 — @updatedAt 데코레이터 추가 확인
21	Market Data @updatedAt 누락	⏮ 스킵	✅ 사유 타당 — PriceHistory, Candlestick, News는 이벤트성 데이터로 updatedAt 불필요
22	PriceAlert 복합 인덱스 누락	✅ 수정 완료	✅ 검증 완료 — @@index([userId, symbol, isActive]) 추가 확인

2.4 인프라 (#23~#33)

#	항목	2차 상태	3차 검증
23	컨테이너 로깅 설정 미적용	✅ 수정 완료	✅ 검증 완료 — json-file + max-size 10m, max-file 3 전 서비스 적용
24	CPU 제한 미설정	✅ 수정 완료	✅ 검증 완료 — postgres 1.0, redis 0.5, kafka 1.5 설정 확인
25	pgAdmin/Redis Commander 헬스체크	✅ 수정 완료	✅ 검증 완료 — wget 기반 헬스체크 추가 확인
26	서비스별 DATABASE_URL 미기재	✅ 수정 완료	✅ 검증 완료 — .env.example에 5개 URL 추가 확인
27	환경변수 검증 부재	✅ 수정 완료	✅ 검증 완료 — 6개 서비스 main.ts에 부트스트랩 검증 확인
28	backup-db.sh 비밀번호 폴백	✅ 수정 완료	✅ 검증 완료 — :? 구문 적용 확인
29	turbo.json 환경변수 의존성	✅ 수정 완료	✅ 검증 완료 — globalDependencies에 .env 추가 확인
30	NestJS 버전 불일치	✅ 수정 완료	✅ 검증 완료 — notification, chat, ai-service ^11.0.0 통일 확인
31	Prisma 버전 불일치	⏮ 확인 완료	✅ 검증 완료 — 이미 ^6.3.0으로 통일되어 있음
32	host.docker.internal macOS 전용	✅ 수정 완료	✅ 검증 완료 — Linux 환경 주석 추가 확인
33	scrape_timeout 미설정	✅ 수정 완료	✅ 검증 완료 — 10초 타임아웃 추가 확인

2.5 프론트엔드 성능 & 접근성 (#34~#40)

#	항목	2차 상태	3차 검증
---	----	-------	-------

34	AssetListItem React.memo 미적용	✅ 수정 완료	✅ 검증 완료 — React.memo() 래핑 확인
35	WebSocket 구독 해제 누락	✅ 수정 완료	✅ 검증 완료 — prevSymbolsRef + unsubscribe 로직 확인
36	AssetList 필터 핸들러 useCallback	✅ 수정 완료	✅ 검증 완료 — handleCategoryChange, handleSortChange useCallback 적용
37	AI Insights 지연 로딩 미적용	✅ 수정 완료	✅ 검증 완료 — dynamic(() => import(...)) 적용 확인
38	OrderSheet 닫기 버튼 터치 영역	✅ 수정 완료	✅ 검증 완료 — p-3 (48px) 적용 확인
39	BottomNav aria-label 누락	✅ 수정 완료	✅ 검증 완료 — 7개 Link 전부 aria-label 추가 확인
40	아바타/심볼 아이콘 대체 텍스트	✅ 수정 완료	✅ 검증 완료 — aria-label={asset.symbol} 추가 확인

2.6 프론트엔드 상태 & UX (#41~#46)

#	항목	2차 상태	3차 검증
41	주문 수정 중복 클릭 방지	✅ 수정 완료	✅ 검증 완료 — modifyOrder.isPending early return 확인
42	SMS 인증 중복 제출 방지	✅ 수정 완료	✅ 검증 완료 — isSubmittingRef guard 확인
43	AI Insights 에러 상태 미표시	✅ 수정 완료	✅ 검증 완료 — isError 시 에러 UI 렌더링 확인
44	채팅방 나가기 확인 모달	✅ 수정 완료	✅ 검증 완료 — window.confirm 호출 확인
45	프로필 수정 버튼 스타일 불일치	✅ 수정 완료	✅ 검증 완료 — 취소/저장 버튼 h-11 통일 확인
46	ConnectionGuard 메시지 하드 코딩	✅ 수정 완료	✅ 검증 완료 — useTranslation 혹 적용, i18n 키 추가 확인

2.7 코드 품질 (#47~#50)

#	항목	2차 상태	3차 검증
47	에러 메시지 한영 혼용	📝 인지	✅ 사유 타당 — 현재 디버깅에 영향 없음, 향후 개선 예정
48	내부 API Swagger 문서 부재	✅ 수정 완료	✅ 검증 완료 — @ApiTags, @ApiOperation 데코레이터 추가 확인

49	BigInt prototype 전역 변경	✅ 수정 완료	✅ 검증 완료 — BigIntSerializerInterceptor로 이관, prototype 변경 제거 확인
50	strictPropertyInitialization 비활성	🔍 스킵	✅ 사유 타당 — 전역 tsconfig 변경 영향 범위가 넓어 현 단계 미적용 합리적

3. 회귀 테스트

3.1 백엔드

서비스	변경 항목	회귀 여부
api-gateway	CORS, 에러 핸들링, 경쟁 조건	✅ 이상 없음
user-auth	이메일 마스킹, 로그인 로그, Prisma 인덱스	✅ 이상 없음
order-engine	Prisma @updatedAt	✅ 이상 없음
portfolio	BigInt 인터셉터, 타입 수정, 입력 검증	✅ 이상 없음
market-data	에러 핸들링, 뉴스 동시 실행 방지	✅ 이상 없음
notification	NestJS v11 업그레이드, 에러 핸들링	✅ 이상 없음
chat	NestJS v11, 권한 검증, 헤더 디코딩	✅ 이상 없음
ai-service	NestJS v11 업그레이드	✅ 이상 없음

3.2 프론트엔드

영역	변경 항목	회귀 여부
성능 최적화	React.memo, useCallback, dynamic import	✅ 이상 없음
접근성	aria-label, 터치 영역	✅ 이상 없음
상태 관리	중복 방지, 에러 UI	✅ 이상 없음
UX	확인 모달, 스타일 통일, i18n	✅ 이상 없음
WebSocket	구독 해제 로직	✅ 이상 없음

3.3 인프라

영역	변경 항목	회귀 여부
Docker Compose	이미지 고정, 로깅, CPU, 헬스체크	✅ 이상 없음
환경변수	.env.example, 부트스트랩 검증	✅ 이상 없음
빌드 설정	turbo.json, NestJS v11, Prisma 통일	✅ 이상 없음
모니터링	Prometheus 설정	✅ 이상 없음

4. 종합 평가

4.1 수정 검증 결과

상태	건수
✔ 수정 검증 완료	45
✔ 스킵 사유 타당	4
✔ 인지 사유 타당	1
✖ 미수정/회귀	0
합계	50

4.2 주요 개선 효과

영역	1차 감사 후	2차 감사 후	개선 내용
보안	기본 수준	강화 완료	CORS 검증, 보안 헤더, 민감 데이터 마스킹, 권한 검증
에러 핸들링	Silent failures 다수	로깅 전환 완료	모든 빈 catch 블록에 logger.warn 추가
타입 안전성	any 타입 산재	타입 정의 완료	백엔드/프론트엔드 any 타입 제거
접근성	일부 미비	WCAG 준수 향상	aria-label, 터치 영역 48px, 대체 텍스트
인프라	기본 구성	프로덕션 수준	이미지 고정, 로깅, CPU 제한, 헬스체크, 환경변수 검증
코드 품질	전역 prototype 변경	패턴 개선	BigInt 인터셉터, Swagger 문서, 경쟁 조건 해결

4.3 시스템 성숙도 평가

항목	점수 (5점 만점)
보안	★★★★☆ (4/5)
데이터 무결성	★★★★☆ (4/5)
에러 핸들링	★★★★☆ (4/5)
인프라 안정성	★★★★☆ (4/5)
프론트엔드 품질	★★★★☆ (4/5)
코드 품질	★★★★☆ (4/5)
종합	★★★★☆ (4.0/5)

4.4 잔여 권고사항 (향후 감사)

우선순위	항목	비고
중	에러 메시지 한영 통일 (#47)	현재 인지 상태, 코드 일관성 향상 필요

중	strictPropertyInitialization (#50)	점진적 도입 검토 (서비스별 개별 적용)
하	E2E 테스트 확대	Playwright 기반 통합 테스트 추가
하	Circuit Breaker 도입	서비스 간 장애 전파 방지
하	중앙 로깅 시스템	Loki/ELK 스택 도입

본 보고서는 VirtuEx 시스템의 3차 감사 결과이며, 2차 감사 수정 사항에 대한 검증 보고서입니다.